

****Supervision of Notification of Breach of Personal Data Security****

Date: 31-08-2023

****Decision****

Public Authorities

No Criticism

Supervision / Self-initiated Case

Notification of Breach of Personal Data Security

The Danish Data Protection Agency has conducted 16 planned inspections focusing on municipalities' and banks' handling of breaches of personal data security. The Data Protection Agency found reason to express criticism in two cases.

Journal Number: 2021-423-0240.

Kalundborg Municipality was among the public authorities that the Data Protection Agency selected for supervision in the spring of 2021 under the General Data Protection Regulation [1] and the Data Protection Act [2].

The Data Protection Agency's supervision was a written inspection that focused on whether Kalundborg Municipality had implemented appropriate security measures in accordance with Article 32, paragraph 1 of the General Data Protection Regulation, aimed at reducing the number of breaches of personal data security involving unauthorized disclosure of personal data, including in relation to citizens with name and address protection.

The supervision was announced in a letter dated June 21, 2021, to Kalundborg Municipality, and the municipality was simultaneously requested to answer a series of questions and to submit an example of an instruction to the municipality's employees regarding the handling of personal data, including in connection with the transmission of information to, among others, citizens, authorities, etc.

The Data Protection Agency informed that the background for the supervision was that, through a review of the Agency's cases regarding notifications of breaches of personal data security, it could be established that Kalundborg Municipality had reported significantly more breaches of personal data security per inhabitant in the municipality than other municipalities in Denmark.

The Data Protection Agency noted in this context that the higher number of notifications does not necessarily indicate that the municipality complies with data protection regulations to a lesser extent than municipalities that have significantly fewer notifications per inhabitant.

In a letter dated July 22, 2021, Kalundborg Municipality sent a statement in which the municipality responded to the Data Protection Agency's questions. The municipality's response was also accompanied by examples of relevant procedures and guidelines.

****Summary****

In the summer and autumn of 2021, the Data Protection Agency initiated written inspections of the handling of breaches of personal data security by eight larger municipalities and eight larger banks. The inspections were organized so that the municipalities and banks were divided into two groups – those that had reported the most and the fewest breaches in relation to the municipality's population and the number of employees in the bank, respectively.

"One of the new things that came with GDPR over five years ago was that data controllers, as a rule, must report all breaches of personal data security to the Data Protection Agency within 72 hours, and they must also internally document all breaches of personal data security, regardless of whether they need to be reported to the Data Protection Agency or not. Furthermore, there has been an increased focus on what companies and authorities need to consider when customers' or citizens' information is mishandled by mistake," says Vibeke Dyssemark Thomsen, chief consultant at the Data Protection Agency, and continues: "This can, for example, lead to the need to implement new or additional security measures to reduce the risk of further breaches. Therefore, we have now conducted a service review of the area, where we have looked at the procedures and taken some samples. The conclusion is broadly that the 16 selected municipalities and banks appear to have the right focus on complying with the rules."

****Group with the Most Reported Breaches****

For the group with the most reported breaches, the inspections focused on whether the municipalities

and banks had implemented appropriate security measures aimed at reducing the number of breaches of personal data security where unauthorized disclosure of personal data occurred in connection with the transmission of information to, among others, citizens, authorities, etc., including in relation to citizens with name and address protection and financial information.

Compliance with the rules on appropriate processing security will normally entail that:

The data controller must ensure that information about data subjects, including particularly confidential and sensitive personal data, does not become known to unauthorized persons. The data controller must, in this context, ensure that all employees in the organization are familiar with any internal procedures for handling personal data, including in relation to the transmission of personal data to, among others, citizens, authorities, etc.

Procedures, guidelines, workflows, technical security measures, etc. are continuously updated or introduced, including as a result of identified breaches of personal data security.

The Data Protection Agency found on the basis of the available information that all data controllers had implemented appropriate security measures. In its assessment, the Data Protection Agency emphasized that:

Procedures, etc. had been developed and activities had been carried out to educate employees in data protection, including to ensure that they are aware that there is no accidental disclosure of personal data to an incorrect recipient.

They have considered and continuously implemented both

****Technical and Organizational Measures in**

Extension of Past Breaches of

Personal Data Security to Avoid Similar Breaches.**

There is a strong focus on avoiding unintentional disclosure of confidential information, which is supported both by business processes, ongoing guidance, etc., and systematic measures, etc.

****The Group with the Fewest Reported Breaches****

For the group with the fewest reported breaches, the inspections focused on whether the municipalities and banks report and document breaches of personal data security in accordance with the requirements of the General Data Protection Regulation, including their processes for handling and recording breaches of personal data security.

The Data Protection Authority stated in these cases that it is the Authority's opinion that compliance with the rules that breaches of personal data security must, as a general rule, be reported to the Data Protection Authority within 72 hours implies that:

1. The data controller must establish appropriate procedures and guidelines to ensure that breaches are detected and handled correctly.
2. In this context, the data controller must ensure that all employees in the organization are familiar with internal procedures for handling breaches of personal data security to the necessary extent, and that relevant employees can identify, handle, and assess breaches of personal data security.

The Data Protection Authority found that all the data controllers, overall, have adopted appropriate procedures and guidelines, etc., and have carried

out appropriate training activities that can support compliance with the requirements of the General Data Protection Regulation regarding the reporting of breaches of personal data security. Thus, they can ensure that breaches of personal data security are captured within the organization, so that they can be assessed to determine whether the breach should be reported to the Data Protection Authority, as well as to document the breaches, including the reasons for not reporting them to the Data Protection Authority.

However, the Data Protection Authority noted in relation to all inspections that the Authority did not have the opportunity, as part of the inspection, to take a specific position on whether all relevant employees have completed the relevant training activities, and that the Authority is not familiar with the full content of the training materials, including the content of, for example, ongoing awareness initiatives.

Furthermore, the Data Protection Authority stated that the rule requiring the data controller to document all breaches of personal data security, including the actual circumstances of the breach, its effects, and the remedial measures taken, must ensure that the Data Protection Authority can verify that the provision regarding the reporting of breaches of personal data security is complied with. The data controllers should therefore document their reasons for all significant decisions made as a result of the breach. This applies not least if the data controller, after assessing the breach, has concluded that it should not be reported to the Data Protection Authority. The documentation should in relation to this decision include a detailed explanation of why the data controller believes that the breach is unlikely to result in a risk to the rights and freedoms of individuals.

****Criticism in Two Cases****

As mentioned, there is pronounced criticism in two of the cases – specifically regarding two municipalities that did not document all breaches of personal data security. In one case, the Data Protection Authority expressed serious criticism of Roskilde Municipality for not documenting how many breaches of personal data security the municipality has identified in the period from May 25, 2018, to September 2019, and that the municipality cannot document whether the registered security incidents since September 2019 constitute actual breaches of personal data security.

In the other case, the Data Protection Authority criticized Frederikshavn Municipality for not

documenting how many breaches of personal data security the municipality identified in 2018.

The Data Protection Authority notes that the list of breaches – in addition to serving as documentation to the Data Protection Authority – should also be used by the data controller to gain an overview of which breaches typically occur in the organization, and based on that, to consider whether there is a need to implement new or supplementary measures to avoid or further reduce the risk of additional breaches. It is also evident from the received consultation responses that several of the data controllers actively use the lists for this purpose.

****1. Decision****

After reviewing the submitted material, the Data Protection Authority finds on the existing basis that Kalundborg Municipality has taken appropriate security measures in accordance with Article 32, paragraph 1, of the General Data Protection Regulation, to reduce the number of breaches of personal data security involving unauthorized disclosure of personal data, including in relation to citizens with name and address protection.

Below follows a detailed review of the information that has emerged in connection with the inspection, and a justification for the Data Protection Authority's decision.

****2. Justification for the Data Protection Authority's Decision****

It appears from Article 32, paragraph 1, of the General Data Protection Regulation that the data controller must implement appropriate technical and organizational measures to ensure a level of security appropriate to the risks associated with the data controller's processing of personal data.

The data controller thus has an obligation to identify the risks that the data controller's processing poses to the data subjects and to ensure that appropriate security measures are implemented to protect the data subjects from these risks. It is the opinion of the Data Protection Authority that the requirement under Article 32 for appropriate security will generally entail that the data controller must ensure that information about data subjects, including particularly confidential and sensitive personal data, does not come to the knowledge of unauthorized persons, and that the data controller must, in this context, ensure that all employees in the organization are adequately familiar with any internal procedures for handling personal data, including in relation to the transmission of personal data to, among others, citizens, authorities, etc., and that procedures, guidelines, workflows, technical security measures, etc. are continuously updated or introduced, including as a result of identified breaches of personal data security.

Kalundborg Municipality has, in its statement of July 22, 2021, provided examples of guidelines and instructions for the municipality's employees regarding the handling of personal data, including in connection with the transmission of information to, among others, citizens, authorities, etc. The municipality has also stated that ongoing training and education are conducted for managers and employees, including two annual workshops focusing on the processing of personal data and information security.

Kalundborg Municipality has further stated that there is a strong focus among individual caseworkers on not disclosing confidential information about one parent to another, particularly in relation to name and address protection. The processes and considerations regarding this are typically incorporated concretely into the areas they concern, as it is a common, integrated part of the considerations that each employee makes in relation to confidentiality obligations. It has also been stated that these considerations often arise in connection with requests for access to documents, when access to AULA is to be granted, as well as when inquiries are received regarding information about a child under the Parental Responsibility Act. Attention to this is, among other things, supported by the fact that it is mentioned in a guide about AULA regarding the establishment of contact parents, that it is directly indicated in AULA whether there is name and address protection, that it is incorporated into standard templates for access requests, and that a process description has been developed regarding the right to information under the Parental Responsibility Act.

Furthermore, it appears from the case that Kalundborg Municipality has made considerations following past breaches of personal data security, where there has been an unintentional disclosure of personal data. Based on these considerations, the municipality has continuously implemented organizational measures, including the implementation of security rules as well as the development of procedures and guidelines, and the development of action plans, etc. Furthermore, the municipality has implemented technical measures, such as a security license package. The municipality has also stated that it has planned to initiate additional technical and organizational measures aimed at reducing the number of breaches of personal data security, where there is unintentional disclosure of personal data.

It is – despite the fact that the Data Protection Authority has not had the opportunity to take a concrete position on whether all relevant employees have completed the relevant training activities, and that the authority is not familiar with the full content of all training materials, including the content of, for example, teaching courses – based on the information available, the authority's assessment is that Kalundborg Municipality has taken appropriate security measures in accordance with Article 32, paragraph 1 of the General Data Protection Regulation, aimed at reducing the number of breaches of personal data security, where there is unauthorized disclosure of personal data, including in relation to citizens with name and address protection.

In its assessment, the Data Protection Authority has placed emphasis on the information provided by the municipality, including that procedures, etc., have been developed and activities have been carried out to educate employees in data protection, including ensuring that they are aware that there is no unintentional disclosure of personal data to an incorrect recipient, that the municipality has made considerations and implemented both technical and organizational measures following past breaches of personal data security to avoid similar breaches, and that there is a strong focus on avoiding unintentional disclosure of name and address protected information, which is supported both systemically and by procedures, standard templates, etc.

The Data Protection Authority can, upon a renewed review of the authority's cases regarding reports of breaches of personal data security, ascertain that since June 21, 2021, there has been a decrease in the number of reported breaches of personal data security from Kalundborg Municipality. However, since a number of breaches of personal data security continue to be reported, where there has been unauthorized disclosure of personal data, the Data Protection Authority recommends that the municipality continues to focus on conducting training and awareness activities, etc., and to ensure that procedures, guidelines, workflows, technical security measures, etc. are continuously updated or introduced, including as a result of identified breaches of personal data security.

The Data Protection Authority notes in conclusion that the authority – typically if it receives new reports of breaches of personal data security – will be able to resume the processing of previously reported breaches or include them in the assessment of any future breach or complaint cases.

[1] Regulation (EU) 2016/679 of the European Parliament and of the Council of 27 April 2016 on the protection of natural persons in relation to the processing of personal data and on the free movement of such data and repealing Directive 95/46/EC (General Data Protection Regulation)

[2] Act No. 502 of 23 May 2018 on supplementary provisions to the regulation on the protection of natural persons in relation to the processing of personal data and on the free movement of such data. (Data Protection Act)